

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Customer operating KEYBOX, EHR, secret-store, or keyless recovery product
Management units responsible	Product Engineering; Security; Legal / Compliance; Data Protection
DPO or similar function	Customer DPO or privacy contact

Processor(s) and Sub-processor(s)

#	Processor	Obligations and Tasks
1	co-mission LLC / Shyware	Provides SDK, shystore client, optional hosted API, reconciliation su
2	Cloud infrastructure provider	Hosts API, canonical node, database, backups, and security infrastru
3	Identity verification provider	Supports identity-gated recovery or reveal workflows where enabled b
4	EHR or identity federation provider	Provides customer-authorized source records or authentication conte

Name of the Processing

Internal name: Shyware Confidential Store / KEYBOX Keyless Recovery DPIA

Repository evidence: Consumers/KEYBOX; shyware/sdk/web/clients/embodiments/storeClient.js;
shyware/domain/state/shystore; shyware/services/reconcile; patent/mainhub/dpia/evidence_index.m

DPIA Technical Sheet

Field	Value
Current version	0.1 draft
Reason to conduct DPIA	Potential high-risk processing because the product can store sealed secrets, EHR-sty
Scope	Confidential store and keyless recovery workflows using shystore-v1, sealed payloads
Publication	Internal domain DPIA; customer-specific adaptation required before production use

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category
1	Sealed secret payload	Customer-configured secret, health record, recovery data, credential metadata, c
2	Secret identifier	Opaque nonce-derived or nonce-plus-payload identifier
3	Identity or recovery hash	Identity hash, Didit/Identus proof hash, or customer account commitment
4	Off-chain linkage record	Mapping between identity hash and secret/submission identifier
5	Audit and closure record	Counts, signatures, Merkle roots, closure evidence
6	Support/admin data	Customer administrator contact, support ticket, configuration metadata

Purposes of the Processing

#	Purpose	Legal Basis Assumption
1	Confidential storage of customer user records	Customer determines basis; likely contract performance
2	Keyless recovery or identity-gated reveal	Customer determines basis; heightened transparency an
3	Audit and integrity verification	Legitimate interests / legal obligation depending deploy
4	Security, abuse prevention, and service operation	Legitimate interests / contract performance

Nature, Scope and Context The processing supports confidential storage and recovery for customer-configured payloads. In the KEYBOX example, the product surface includes EHR-oriented flows and selective disclosure. Payloads are intended to be sealed before write or storage. The highest-risk element is not canonical state alone, but the combination of sensitive payloads, identity-gated recovery, and any off-chain linkage store.

Mainhub Patent Alignment The Mainhub patent architecture supports canonical-state non-representability of the identity–payload join where the two-list rejection predicate is correctly implemented. For this domain, that guarantee does not cover plaintext before sealing, customer-selected payload schema, identity-gated recovery, EHR-style content, support workflows, backups, or off-chain linkage records. Residual risk must therefore be assessed at the protected-linkage and payload-governance layers, not only at the canonical state layer.

Authority Partition This is a sealer-governed embodiment (no unique-person count-match). Three parties:

Authority	Role	Str
Auth (Cognito)	Account layer; always required; also the delete-only authority for this embodiment	Re
IDV/KYC (Didit)	Verifies account belongs to a real, verified person; assessed on authenticated users	Ca
Reconciling authority	Off-chain linkage store + sealer keys	Eli

Because this is a sealer-governed deployment, no eligibility authority key is registered and the rescission mechanism is structurally unavailable. The worst-case unilateral threat is payload disclosure via the sealer (reconciling authority).

Art. 17 erasure (Claim 2, shystore-v1): Verified by KEYBOX ERASURE section — **VERIFIED (run 25724794650):** DELETE returns 200; subsequent GET returns 404 (14/14 assertions pass).

Functional Description

Phase	Operation	Explanation
Collection	Customer app receives user records or secrets	Customer decides
Sealing	Payload encrypted client-side or before broadcast	ABCI/canonical l
Canonical write	SecretStore or related transaction committed	List 1 stores seale
Recovery	User re-authenticates through configured authority	Reconciliation pat
Deletion	Customer instruction or user request triggers deletion/render unavailable	Must cover canon

ANALYSIS OF THE PROCESSING

Lawfulness of the Processing

Customer controllers must define the lawful basis per deployment. Shyware should not provide a universal legal-basis conclusion because the payload may range from ordinary secrets to health data. If health records, biometric-derived recovery, financial credentials, or employee records are processed, counsel must assess Article 9 GDPR, local health/privacy law, and sector-specific retention rules.

Data Minimisation, Retention Periods, and Data Quality

Data Item	Minimisation Position	Open Review Item
Sealed payload	Store only fields necessary for the customer purpose	Define prohibited fields a
Identity hash	Scope to product, tenant, and recovery domain	Confirm no cross-product
Off-chain linkage	Disable unless recovery/reveal is required	Define access policy, logg
Local storage	Use least persistent storage compatible with user workflow	Define browser/mobile d
Telemetry	Exclude payload plaintext, identity hash, proof hash, and nonces	Confirm filters in produc

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The confidential store pattern may be proportionate where keyless recovery, auditability, and user-controlled disclosure are necessary for the customer product. It becomes harder to justify if customers use it as a general-purpose vault for unrestricted sensitive data without schema controls, retention limits, or a clearly bounded recovery path.

RISK ASSESSMENT AND MANAGEMENT

Risk Assessment and Management

Threats

#	Threat	Materialisation
1	Sensitive payload exposure	Sealer key compromise, client compromise, or plaintext logging
2	Recovery authority overreach	Reconciliation endpoint reveals or links records beyond user instruction
3	Cross-domain linkability	Identity hash reused across products or tenants
4	EHR or special-category misuse	Customer stores health/sensitive data without legal basis or notice
5	Deletion failure	Canonical/off-chain/local/backup stores diverge

Additional Mitigating Measures

#	Measure	Status
1	Require payload schema review and restricted-data policy before production	See patent/
2	Scope identity hashes per tenant, app, and recovery domain	See patent/
3	Dual-control reconciliation for reveal/recovery of high-risk payloads	See patent/
4	Explicit telemetry exclusion checks for payloads, hashes, proof values, and nonces	See patent/
5	End-to-end deletion evidence across canonical, off-chain, local, backup, and provider records	See patent/

DPIA Audit Findings This DPIA is the audit record for the confidential-store processing pattern. The following findings must be resolved in this DPIA or in a customer-specific version before production.

Audit Area	Required Finding
Patent posture	Write-side canonical state may reduce identity–payload linkage only if the reject
Protected linkage / reconcile	Recovery or reveal must be disabled, user-only, or dual-control depending payload
Provider partitioning	Identify IDV/auth provider, linkage store, reconciling authority, canonical comm
Payload/content risk	Health, credential, secret, or support payloads can identify the data subject rega
Endpoint / local state	Browser/mobile cache, support export, backups, and local recovery artifacts may
Residual risk	Generic confidential-store use is not approved without customer-specific legal ba

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** ([patent/mainhub/dpia/source/COM](#) published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production.

- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that eligibility_authority_key $\neq$ reconciling_authority_key $\neq$ auth_key.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while confidential-store payload, recovery, deletion, retention, legal-basis, or customer-configuration choices still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Sensitive payload exposure	Payload sealing, schema review, telemetry exclusions
Recovery authority overreach	Dual-control reconciliation, audit logs, non-enumerable reconcile API
Cross-domain linkability	Tenant/app/recovery-domain scoped identity hashes
EHR or special-category misuse	Customer legal-basis review and restricted-data policy
Deletion failure across stores	End-to-end deletion evidence across canonical, off-chain, local, backup, and p
Provider consolidation	Provider partition matrix for IDV/auth, linkage store, reconcile, commit, and

INVOLVEMENT OF INTERESTED PARTIES

DPO and customer privacy/security stakeholders should review this DPIA before production. Data subject consultation may be appropriate where the customer uses the product for health, employment, education, or other sensitive contexts.

CONCLUSION AND DECISION

Draft decision: Not approved for production as a generic store. Proceed only after customer-specific payload scope, legal basis, identity/recovery mode, retention, deletion, and subprocessor review are completed.